

Data Processing Agreement (DPA) in accordance with Art. 28 of the General Data Protection Regulation (GDPR)

for Interflex Managed Services

between

the Client

- as identified in more detail in the Interflex Managed Services contract -
(Responsible person, hereinafter the "**Client**")

and

Interflex Daten Systeme GmbH

Epplestraße 225
70567 Stuttgart

(Processor, hereinafter the "**Contractor**")

§ 1 Subject matter and duration of this DPA

(1) Subject

The Contractor offers systems for automated access control, visitor management, time recording and workforce management.

This data processing agreement (DPA) applies to all processing of personal data pursuant to the Interflex Managed Services Contract (hereinafter "**Service Agreement**"). This DPA is attached to the Interflex Managed Services Contract as Annex 3.

(2) Duration, termination

The Agreement shall apply for as long as the Contractor processes personal data in the course of the performance of the Service Agreement, unless otherwise agreed.

Either party may terminate the DPA at any time without notice if a serious breach of a party against data protection regulations or the provisions of this DPA. In particular, non-compliance with the obligations agreed in this DPA and derived from Art. 28 GDPR constitutes a serious breach.

§ 2 Concretization of the content of the DPA

Nature and purpose of the intended processing of personal data

The purpose of the processing of personal data by the Contractor for the Client, the types of data processed and the categories of data subjects are described in more detail in the Service Agreement and in **Annex 1 - Data Protection Legal Specification**.

The provision of the contractually agreed data processing currently takes place exclusively in the territory of the Federal Republic of Germany, in a member state of the European Union or in another contracting state of the Agreement on the European Economic Area. A possible later relocation to a third country requires the consent of the Client and must fulfil the special requirements of Art. 44 et seq. GDPR.

§ 3 Authority of the Client to issue instructions

(1) The Contractor shall process the personal data exclusively for the provision of its services under the Service Agreement in accordance with the Client's documented instructions, including with regard to the transfer of personal data to a third country or an international organisation, unless it is obliged to do so by the law of the Union or of a Member State to which it is subject; in such a case, the Contractor shall notify the Client of these legal requirements prior to the processing, unless the law in question prohibits such notification due to an important public interest. The instructions shall otherwise result from the Service Agreement and the setting and configuration of the service carried out by the Client. Individual instructions after the conclusion of the agreement must be in text form and the Client must confirm them in writing if requested by the Contractor.

(2) If the Client issues individual instructions that go beyond the scope of services agreed in the Service Agreement, this shall require the Contractor's consent.

(3) The Contractor shall draw the Client's attention to the fact if, in its opinion, an instruction issued by the Client violates statutory provisions. The Contractor shall be entitled to suspend the implementation of the relevant instruction.

(4) The Client may name to the Contractor, in text form by an authorized person, the persons authorized to issue instructions - or any change of persons authorized to issue instructions - for the execution of the processing under this Agreement. In principle, the responsible key account manager or project manager or service technician are the recipients of instructions in the case of the Contractor, unless a person authorized to represent the Contractor has informed the Client otherwise in text form.

§ 4 Technical-organisational measures

(1) The Contractor shall document the implementation of the agreed technical and organisational measures before the start of the processing, in particular with regard to the specific execution of the Service Agreement, and shall hand them over to the Client for inspection. If accepted by the Client, the documented measures shall become the basis of this DPA. Insofar as an examination/audit of the Client reveals a need for adaptation, this shall be implemented by mutual agreement.

(2) The Contractor shall establish the security of the processing pursuant to Art. 28 (3) lit. c, 32 GDPR, in particular in connection with Art. 5 (1), (2) GDPR. Overall, the measures to be taken are data security measures and measures to ensure a level of protection appropriate to the risk with regard to confidentiality, integrity, availability and the resilience of the systems. The state of the art, the implementation costs and the nature, scope and purposes of the processing as well as the varying likelihood and severity of the risk to the rights and freedoms of natural persons within the meaning of Article 32 (1) of the GDPR shall be taken into account (details in Annex 2, which is an integral part of this DPA).

(3) The technical and organisational measures are subject to technical progress and further development. In this respect, the Contractor is permitted to implement alternative adequate measures. In doing so, however, the security level of the specified measures may not be undercut. Significant changes shall be documented in writing or electronically.

(4) Insofar as the Contractor performs services on the Client's premises, the Contractor shall not be responsible for compliance with the technical and organisational measures which are within the Client's sphere of influence and responsibility.

§ 5 Quality assurance and other obligations of the Contractor

In addition to compliance with the provisions of this commissioned processing, the Contractor shall have legal obligations pursuant to Art. 28 to 33 of the GDPR; in this respect, the Contractor shall in particular ensure compliance with the following requirements:

- a) Written appointment of a data protection officer pursuant to Art. 38 and 39 of the GDPR.

The current contact details of the data protection officer(s) are always available on the Contractor's homepage.

- b) Maintaining confidentiality in accordance with Art. 28 (3) sentence 2 lit. b, 29, 32 (4) GDPR. When carrying out the work, the Contractor shall only use employees who have been obligated to maintain confidentiality and who have previously been familiarised with the data protection provisions relevant to them.
- c) The implementation of and compliance with all technical and organisational measures required for this commissioned processing pursuant to Art. 28 (3) sentence 2 lit. c, 32 GDPR (details in Annex 2, which is part of this DPA).
- d) The Client and the Contractor shall cooperate with the supervisory authority in the performance of its duties upon request.
- e) The immediate information of the Client about control actions and measures of the supervisory authority, insofar as they relate to this commissioned processing. This shall also apply to the extent that a competent authority investigates the Contractor in the context of administrative offence or criminal proceedings with regard to the processing of personal data in the course of the processing under this DPA.
- f) Insofar as the Client, for its part, is exposed to an inspection by the supervisory authority, administrative offence or criminal proceedings, the liability claim of a data subject or a third party or any other claim in connection with the commissioned processing at the Contractor, the Contractor shall support it to the best of its ability.
- g) The Contractor shall regularly monitor the internal processes as well as the technical and organisational measures to ensure that the processing in its area of responsibility is carried out in accordance with the requirements of the applicable data protection law and that the protection of the rights of the data subject is guaranteed.
- h) Upon request by the Client, the Contractor shall provide evidence of the technical and organisational measures taken to the Client within the scope of its control powers pursuant to § 7 of this DPA.
- i) Upon termination of the services to be provided under the Service Agreement or at the request of the Client, the Contractor shall return to the Client, in accordance with the Service Agreement, all documents in its possession and all work results and data created in connection with the Agreement or delete them in accordance with data protection law with the prior consent of the Client.
- j) The Contractor shall retain documentation that serves as proof of proper data processing in accordance with the applicable retention periods beyond the end of the Agreement. The Contractor may hand over the documentation to the Client at the end of this DPA.

§ 6 Subcontracting relationships

(1) Subcontracting relationships within the meaning of this DPA are those services which relate directly to the provision of the main service. This does not include ancillary services where the subcontracting does not primarily concern the processing of personal data, e.g. the use of postal, telecommunications, logistics, cleaning and craftsman services. However, the Contractor shall be obliged to implement appropriate and legally compliant contractual agreements as well as control measures to ensure data protection and data security of the Client's personal data also in the case of outsourced ancillary services.

(2) The Contractor may appoint an external processor (hereinafter referred to as a “**Subcontractor**”). By signing this DPA, the Client gives the Contractor general permission to employ Subcontractors. The Contractor shall inform the Client of any intended change with regard to the engagement or replacement of Subcontractors. The Client may notify any objections to the Subcontractor and, if these are not resolved by mutual agreement, terminate this DPA as of the date on which the change takes effect. No Subcontractors are currently used unless such Subcontractors are listed in **Annex 3 - Subcontractors**.

(3) The Contractor shall at least pass on the obligations under this DPA to its Subcontractors within the framework of (sub)commissioned processing agreements to be concluded, including the guarantee of appropriate technical and organisational measures. These must comply with the requirements of the applicable data protection law.

(4) The Contractor shall enter into confidentiality agreements with all Subcontractors insofar as they are not already subject to a corresponding statutory confidentiality obligation.

§ 7 Control rights of the Client

(1) The Client may, at its own expense, convince itself of the technical and organisational measures taken by the Contractor in accordance with Annex 2 prior to the commencement of data processing and regularly thereafter and document the result. This can be done, among other things, by obtaining a self-disclosure from the Contractor, which the Contractor can also fulfil by submitting a suitable certificate from an expert, or by carrying out an on-site inspection.

(2) The Contractor undertakes to provide the Client, upon written request and within a reasonable period of time, with all information required to carry out a corresponding inspection.

(3) If the Client commissions a third party to carry out the inspection (including an on-site inspection), the Client shall oblige the third party in writing to maintain secrecy and confidentiality, unless the third party is subject to a professional confidentiality obligation. At the request of the Contractor, the Client shall submit the obligation agreements with the third party to the Contractor without delay. The Client may not commission a competitor of the Contractor with the inspection.

(4) Any on-site inspection requires a written advance notice of 30 days, as a general rule, and is limited to ordinary business hours and has to be undertaken in a way so it minimizes any impact of the Contractor's business operations. Routine on-site inspections shall be limited to a maximum of once per calendar year. The Client shall inform the Contractor in writing of the result of its inspection, as a rule within thirty (30) days of completion of the inspection.

§ 8 Rights of the data subjects

(1) The rights of the persons affected by the processing of personal data shall be asserted against the Client.

(2) Insofar as a data subject should contact the Contractor directly for the purpose of information, correction, deletion or blocking of the data concerning him, the Contractor shall forward this request to the Client without delay.

(3) In the event that a data subject asserts its rights under data protection law, the Contractor shall support the Client with suitable technical and organisational measures in the fulfilment of these claims to the extent appropriate and necessary for the Client, provided that the Client cannot fulfil the claims without the Contractor's cooperation.

(4) The Contractor shall enable the Client to correct, delete or block personal data or, at the Client's request, carry out the correction, blocking or deletion itself if and to the extent that this is impossible for the Client itself.

§ 9 Notification in the event of infringements

(1) The Contractor shall assist the Client in complying with the personal data security obligations, data breach notification obligations, data protection impact assessments and prior consultations referred to in Articles 32 to 36 of the GDPR. This includes, among others

- a) Ensuring an adequate level of protection through technical and organisational measures that take into account the circumstances and purposes of the processing as well as the predicted likelihood and severity of a potential security breach and allow for the immediate detection of relevant breach events
- b) the obligation to assist the Client within the scope of its duty to inform the data subject and, in this context, to provide it with all relevant information without delay
- c) the support of the Client for its data protection impact assessment, as far as necessary
- d) the support of the Client within the framework of prior consultations with the supervisory authority

(2) The Contractor is aware that the Client may be subject to a notification obligation pursuant to Art. 33 of the GDPR, which provides for notification to the supervisory authority within 72 hours of becoming aware of the matter. The Contractor shall support the Client in the corresponding reporting obligations.

(3) The Contractor shall inform the Client without delay if it becomes aware of a personal data breach within the scope of the commissioned processing.

(4) Insofar as the Client is subject to statutory duties to provide information due to unlawful acquisition of personal data, the Contractor shall support the Client in fulfilling the duties to provide information at the Client's request within the scope of what is reasonable and necessary. The cooperation is subject to remuneration, unless it is included in the service description or the violation is due to the fault of the Contractor.

§ 10 Correction, restriction and deletion of data

(1) The Contractor may not correct, delete or restrict the processing of data processed under this DPA on its own authority, but only in accordance with documented instructions from the Client. Insofar as a data subject contacts the Contractor directly in this regard, the Contractor shall forward this request to the Client without delay.

(2) Data that the Contractor processes only for the performance of its services (e.g. maintenance) are deleted as soon as they are no longer required for the provision of the respective service (cf. Annex 2 (Access Control)).

§ 11 Liability

Art. 82 GDPR shall apply. Insofar as the Service Agreement contains provisions on liability, these shall also apply to the internal relationship of the parties within the scope of this DPA.

§ 12 Compensation obligation

(1) Insofar as the Contractor is obliged by this DPA to perform services which are not included in the scope of services according to the Service Agreement ("**Additional Services**"), these shall be remunerated separately according to time and material expenditure. This is in particular the case for the services described in § 3(2), § 5 lit. d) and f), § 7 (insofar as services are not required due to a data protection breach for which the Contractor is responsible), § 8 and § 10 activities mentioned above. The Parties clarify that, insofar as the Contractor should have unlawfully caused Additional Services, the Client shall not owe any remuneration pursuant to this § 12.

(2) Subject to the Service Agreement or other agreements between the parties, a flat hourly rate of EUR 180 per hour plus statutory VAT shall apply to the remuneration of the Contractor's labour for Additional Services. The Contractor shall invoice the Client for the cost of materials and travel expenses in the amount actually incurred plus VAT. Should the Contractor be able to prove a higher cost, he may invoice the higher amount.

§ 13 Miscellaneous

(1) Additions and amendments to this DPA must be made in writing. This also applies to any waiver of the written form requirement.

(2) Should any provision of this DPA be legally invalid, this shall not affect the validity of the remaining provisions. The ineffective provisions shall be replaced retroactively by a provision that is as close as possible in terms of content to the economic purpose of the intended provision.

(3) The defence of the right of retention within the meaning of section 273 BGB (German Civil Code) shall be excluded with regard to the data processed for the Client and the associated data carriers.

(4) Should the Client's data at the Contractor be endangered by attachment or seizure, by insolvency or composition proceedings or by other events or measures of third parties, the Contractor shall inform the Client thereof without delay. The Contractor shall immediately inform all persons responsible in this context that the sovereignty and ownership of the data lies exclusively with the Client as the person responsible within the meaning of the GDPR.

(5) This DPA shall be governed by German law to the exclusion of the application of private international law. The exclusive place of jurisdiction for all disputes arising from and in connection with this DPA is Stuttgart, Germany.

Appendix 1 - Data protection specification: Interflex Managed Services:

This Annex 1 (Data Protection Specification) must be read together with the concluded Service Agreement (Interflex Managed Services Contract). It goes without saying that only the personal data that are part of the agreed scope of services will be processed.

Categories of persons concerned:

1. Employees who use the IF system
2. Visitors/foreign workers, if applicable with visitor/guest pass for the IF system, if corresponding module agreed in the Service Agreement.

Data types:

The following types of data may be processed by the Contractor, insofar as they are part of the commissioned service:

Badge creation data	Personalisation data for the visible imprint on the ID medium (surname, first name, signature if applicable and digital photo if applicable). This data and, if applicable, the date of signature can be stored in the module for the creation of the ID card.
Visitor external company data	Registration data, if applicable for the visible imprint on the identification medium/pass (surname, first name, signature if applicable and digital photo of the person concerned if applicable). Length of stay, pre-registration data, person visited, reason for visit, individual visitor, permanent visitor.
Booking data Time recording including web client	Booking type Time recording with booking terminal, time stamps and balances of the time accounts; missing reasons (business trip, business trip, sick, seminar, holiday, etc.); absences (from to); absence totals (hours per day) - The Client determines the possibilities/admissibility of the missing reason entries and missing reason displays.
Booking data access	Booking type Access with booking terminal, time stamp and result of the authorisation check.
Login data	Login data
Payroll accounts	Hourly totals for the salary/settlement system
Staff planning and control data	Functions, qualifications, time availability, shift schedules/workplace planning, statistical data from the ACD (telephone system) for preparing staffing requirements, time account evaluations.
Personal master data	Master record number, badge number, surname, first name, personnel number, department and the optional fields, if these are used by the Client in the system.
Pre-calculator data	Data transfer/ data exchange with payroll system. Data records consisting of: Master record number, badge number, surname, first name, personnel number, department, booking data time recording and the optional fields, if these are used by the Client in

	the system. Data communication depends on the respective configuration (customising) of the interface.
Workflow data Access control	Applications for access authorisations; approver and feedback approved yes/no; e-mail address official for workflow communication.
Workflow data Time recording	Requests for corrections, reasons for errors, absences; approver and feedback approved yes/no; e-mail address official for workflow communication.

Annex 2 - Technical-organisational measures

1. confidentiality (Art. 32 para. 1 lit. b GDPR)

- Access control
No unauthorised access to data processing facilities, whereby the term is to be understood spatially.

Technical or organisational measures for access control, in particular also for the legitimisation of authorised persons:

- ⇒ Access control system with badge readers for chip cards
- ⇒ Key / Key allocation
- ⇒ Door security (electric door openers, etc.)
- ⇒ Reception for visitors

Access to the buildings / parts of buildings at Interflex is by means of electronic IF access control. Visitors / strangers can only enter the building parts of Interflex after registration and release. They are accompanied by the visitor.

- Access control

The intrusion of unauthorised persons into the DP systems shall be prevented.

Technical (password / password protection) and organisational (user master record) measures regarding user identification and authentication:

- ⇒ Controlled password procedure (syntax at least 1 special character or 1 capital letter, 1 digit, lower case, minimum length = 10, regular password change every 90 days, repetition cycle = 24)
- ⇒ Automatic locking (e.g. password or pause circuit)
- ⇒ Set up a user master record per user and function
- ⇒ Encryption of data media with AES 256 bit Zip programme or VeraCrypt or similar programmes.
- ⇒ Encryption / tunnel connection (VPN = Virtual Private Network)

All computer systems at the Contractor's have a user name and an individual password. If necessary, they are manually connected to the intranet via Active Directory. External access to the intranet is only possible via VPN. Access is only granted if the identification data of the computer, user name and password are known there and match. The syntax of the passwords, which must be changed at regular intervals, is at least 10 digits, special characters or upper case letters, lower case letters and at least one digit. The repetition cycle is

24. These conditions are automatically checked when the password is changed, and the new password is rejected if it is not complied with. If a password is not changed in time, it expires and access is denied.

- Access control

Unauthorised activities in data processing systems outside of granted authorisations must be prevented.

Demand-oriented design of the authorisation concept and access rights as well as their monitoring and logging:

- ⇒ Differentiated authorisations and temporary password assignment (according to authorisation concept Interflex System) by the Client
- ⇒ Storage of transferred data on local computers in encrypted containers (e.g. using VeraCrypt or similar programmes). The local computer is also completely encrypted with a company solution.
- ⇒ Access is only granted to the person who carries out the respective order processing

Data provided to the Contractor is kept in local, encrypted containers (e.g. VeraCrypt or similar programmes) for the duration of the work and removed again after completion of the work with a special deletion tool (Eraser). The local data carriers of the computers are also completely encrypted with a company solution. The temporary storage of data is only carried out on the local systems of those who are commissioned with the fulfilment of the order. Only authorised Interflex users have access to the PC.

Access control to the data of the Interflex customer system is regulated by the Client himself by assigning/naming/deleting a temporary password.

- Separation control

Data collected for different purposes shall also be processed separately.

Measures for separate processing (storage, modification, deletion, transmission) of data with different purposes:

- ⇒ "Internal multi-client capability" / earmarking
- ⇒ Separation of functions / production / test

Client data is temporarily stored and processed strictly separately from other Client data in encrypted, password-protected containers. In the case of processing via online remote control, the changes are made directly in the Client's system. There is a separate server for test data.

- Pseudonymisation (Art. 32 para. 1 lit. a GDPR; Art. 25 para. 1 GDPR)
The processing of personal data in such a way that the data can no longer be attributed to a specific data subject without the use of additional information, provided that this additional information is kept separately and is subject to appropriate technical and organisational measures.

Personal data can be pseudonymised or anonymised for a possible data export if required.

2. integrity (Art. 32 para. 1 lit. b GDPR)

- Disclosure control

Aspects of the transfer of personal data shall be regulated: Electronic transmission, data transport, transfer control. No unauthorised reading, copying, modification or removal.

Measures during transport, transmission and transfer or storage on data carriers (manually or electronically) as well as during subsequent verification:

- ⇒ Encryption / tunnel connection (VPN = Virtual Private Network)
- ⇒ Data backups using a zip programme (e.g. Winzip or similar programmes) and 256-bit AES encryption with a password on CD/DVD.
- ⇒ Logging

As a rule, the data is not passed on unless the problem solution requires the cooperation of the development department of the Contractor. If this is necessary, the data backup is either burned on CD/DVD using a zip programme, 256-bit AES encryption and password and sent by post or, in the case of small amounts of data, transferred directly via the intranet using a zip programme and 256-bit AES encryption. The transfer of data backups is recorded in documents.

- Input control

Traceability or documentation of data management and maintenance must be ensured.

Measures to check retrospectively whether data has been entered, changed or removed (deleted) and by whom:

- ⇒ Logging via log file in Interflex system(s).

The IF systems have a log file in which the changes are entered with the respective user ID as well as date and time.

3. availability and resilience (Art. 32(1)(b) GDPR)

- Availability control

The data shall be protected against accidental destruction or loss.

Data backup measures (physical / logical):

- ⇒ Backup procedure according to performance agreement
- ⇒ Virus protection / Firewall
- ⇒ UPS for server

All computer systems are equipped with an antivirus solution. Anti-virus signatures are updated promptly after they appear via the centrally controlled endpoint protection solution.

- Rapid recoverability (Art. 32(1)(c) GDPR);

Security concept (including disaster recovery programme) and service level agreements according to performance agreement

4. procedures for regular review, assessment and evaluation (Art. 32(1)(d) GDPR; Art. 25(1) GDPR)

- Data protection management;
- Incident response management: is included in the ISMS (Information Security Management System).
- Data protection-friendly default settings (Art. 25 (2) GDPR);
- Continuous monitoring
- Backups for test purposes (dedicated customer data)

- Order control

No commissioned data processing within the meaning of Art. 28 GDPR without corresponding instructions from the Client

Measures (technical / organisational) to demarcate competences between Client and Contractor:

- ⇒ Clear contract design in accordance with Art. 28 GDPR

⇒ Formalised order placement (managed services contract or individual orders in text form)

With the exception of the Subcontractors approved by the Client, the Contractor shall carry out the commissioned scope of services himself in accordance with the Client's instructions. In principle, commissioned changes shall only be made in the programmes and in the evaluation logic.

Annex 3 Subcontracting relationships

- a) ☐ Subcontracting does not currently take place.
- b) ☒ The following subcontracting relationships exist as of the date of this DPA:

Company Subcontractor	Address/Country	Power
IONOS SE	Elgendorfer Str. 57, 56410 Montabaur, Germany	Operator Data Centres and Computer Platforms (IaaS)